Module 07: Perimeter Defence Evasion Techniques

```
# Exercise 06: Performing WAF Fingerprinting
```

Scenario

Web Application Firewalls (WAF) inspect incoming HTTP/HTTPS traffic to block malicious payloads such as SQL injection, cross-site scripting (XSS), and directory traversal attacks. Before attempting perimeter evasion, penetration testers perform WAF fingerprinting to identify the presence, product vendor, and exact signature rules of host-based or cloud-delivered WAF solutions (e.g., ModSecurity, Cloudflare, AWS WAF).

Security analysts leverage specialized detection engines such as Nmap's script engine (**nmap --script http-waf-detect certifiedhacker.com**) and specialized fingerprinting utilities like **WhatWaf** (**whatwaf -u http://certifiedhacker.com**). The **-u** option in WhatWaf is used to specify the target URL. Fingerprinting target domains like **http://certifiedhacker.com** reveals underlying protective filters such as ModSecurity and Open Source WAF.

In this exercise, we acquire root privileges on Parrot Security, execute Nmap WAF detection scripts against **certifiedhacker.com**, run WhatWaf using the URL specification option (**-u**), and identify active WAF instances.

Objective

The objective of this lab is to help students learn how to:
- Execute root privilege escalation on Parrot Security (**sudo su**)
- Perform WAF and IDS/IPS detection using Nmap NSE scripts (**nmap --script http-waf-detect certifiedhacker.com**)
- Identify the target URL parameter flag in WhatWaf (**-u**)
- Run **WhatWaf** fingerprinting scans against target websites (**whatwaf -u http://certifiedhacker.com**)
- Identify active WAF software signatures (such as **ModSecurity** and Open Source WAF)

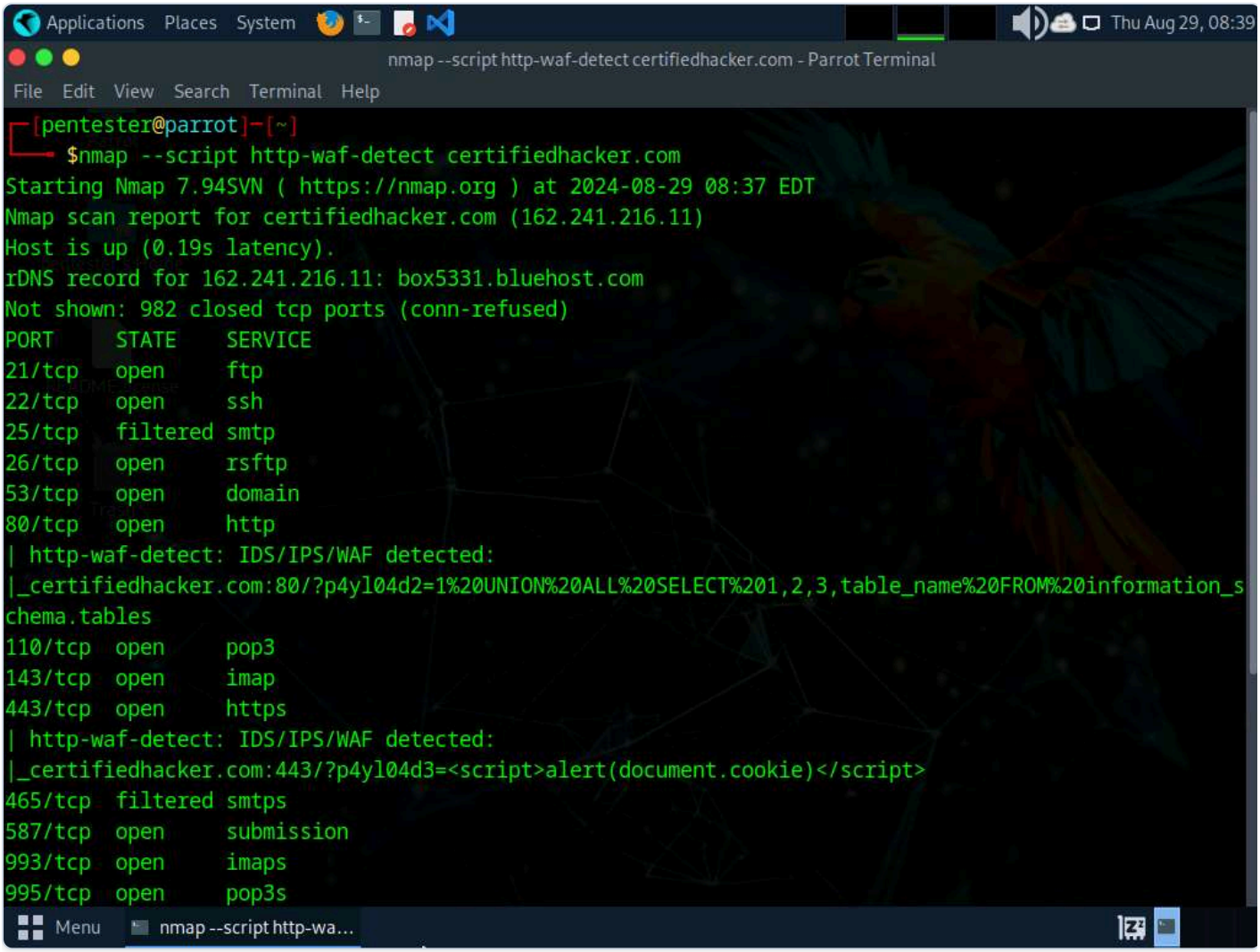
Task 1: Fingerprint Web Application Firewall using Nmap and WhatWaf

In this task, we perform WAF detection using Nmap NSE scripts, execute WhatWaf targeting **http://certifiedhacker.com** via the **-u** parameter flag, and analyze detection signatures.

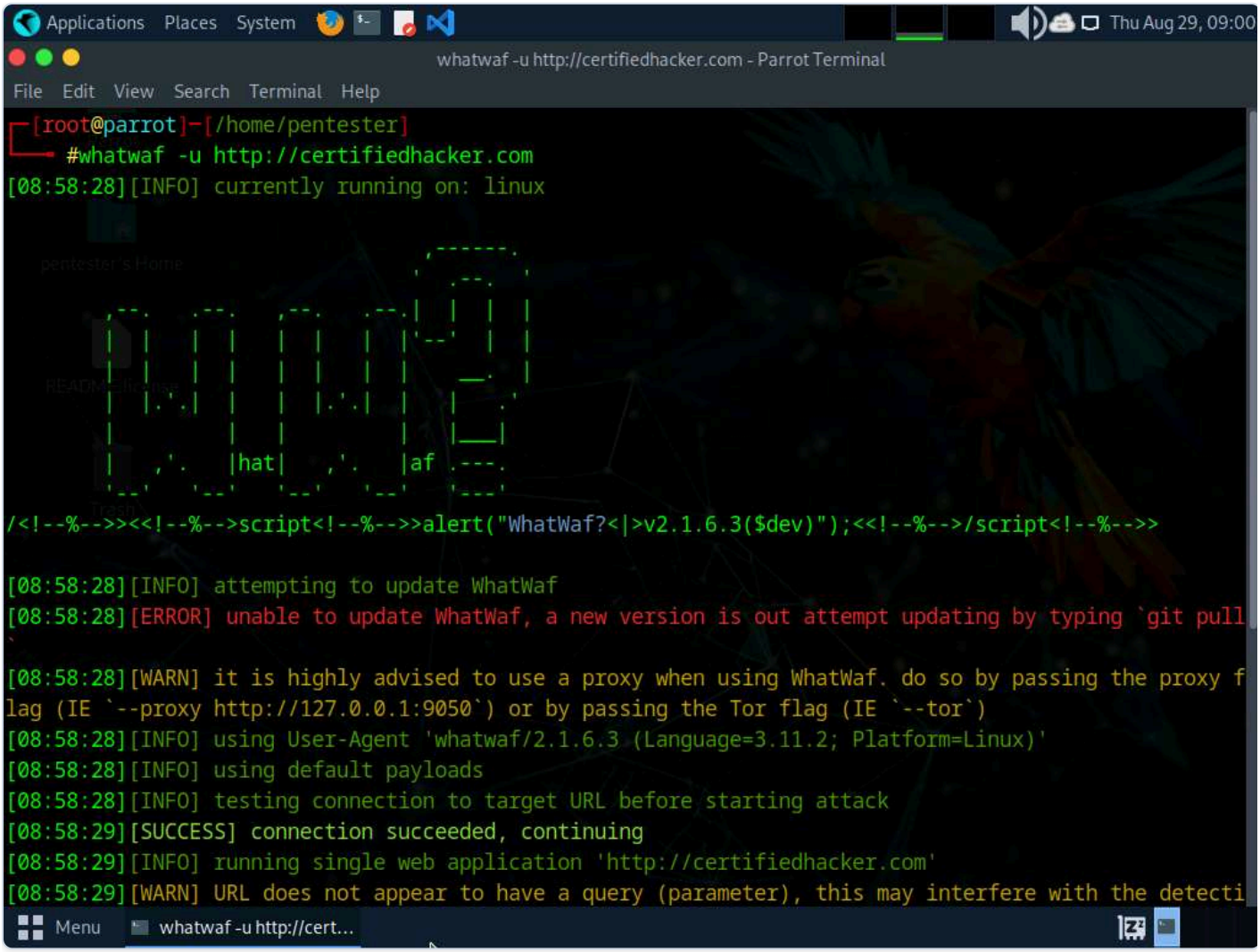
Lab Tasks

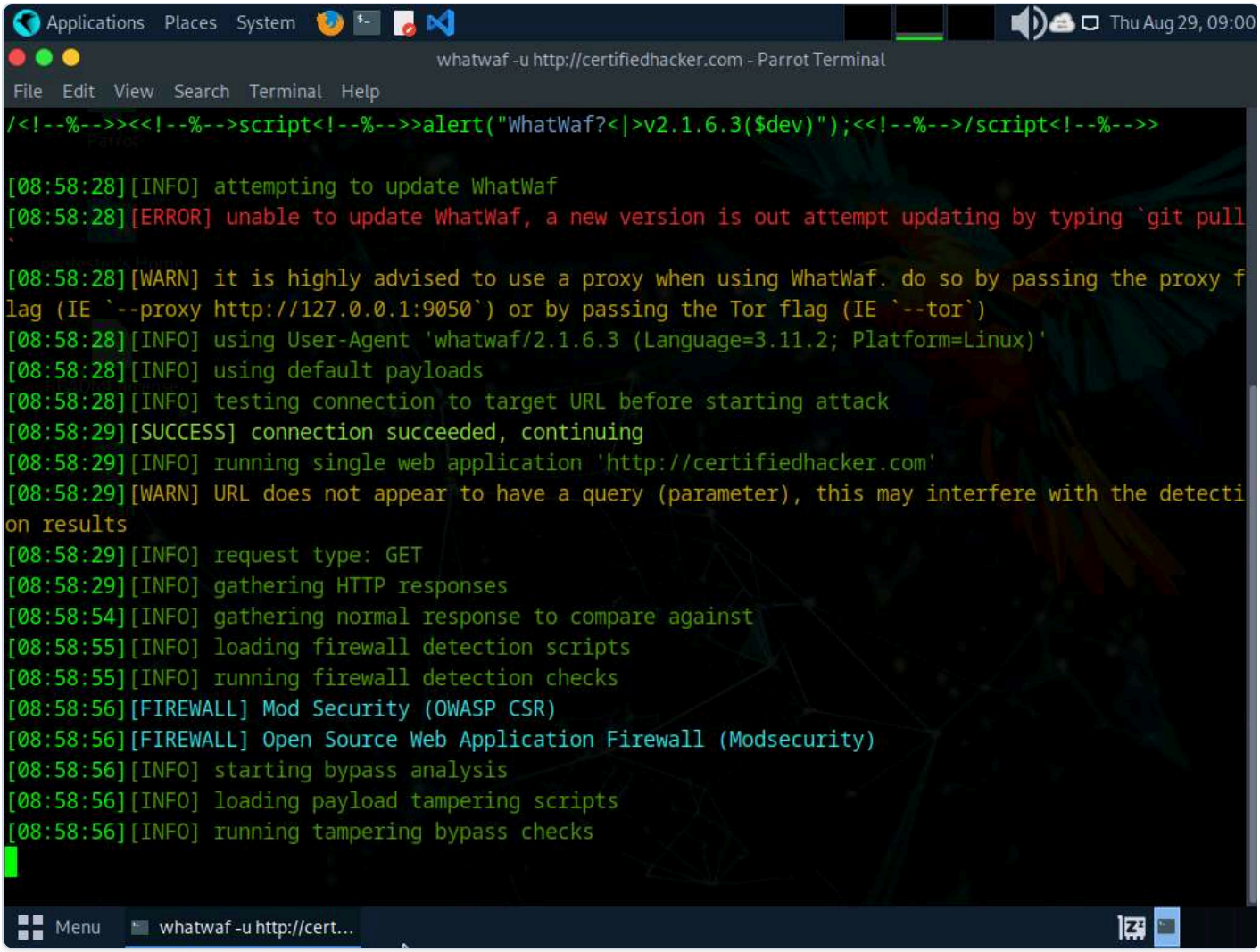
1. Switch to **Parrot Security** (**toor**). Open a terminal and elevate to root:
   sudo su

2. Run Nmap HTTP WAF detection script against the target domain:
   nmap --script http-waf-detect certifiedhacker.com
   Analyze the output to determine if an inline WAF or IDS/IPS is intercepting probes.



1. Execute WhatWaf fingerprinting using the URL option (**-u**):
   whatwaf -u http://certifiedhacker.com


Applications Places System
Thu Aug 29, 09:00
whatwaf -u http://certifiedhacker.com - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester]
#whatwaf -u http://certifiedhacker.com
[08:58:28][INFO] currently running on: linux
/<!--%-->><!--%-->script<!--%-->>alert("WhatWaf?<|>v2.1.6.3($dev)");<!--%-->/script<!--%-->>
[08:58:28][INFO] attempting to update WhatWaf
[08:58:28][ERROR] unable to update WhatWaf, a new version is out attempt updating by typing `git pull
`
[08:58:28][WARN] it is highly advised to use a proxy when using WhatWaf. do so by passing the proxy f
lag (IE `--proxy http://127.0.0.1:9050`) or by passing the Tor flag (IE `--tor`)
[08:58:28][INFO] using User-Agent 'whatwaf/2.1.6.3 (Language=3.11.2; Platform=Linux)'
[08:58:28][INFO] using default payloads
[08:58:28][INFO] testing connection to target URL before starting attack
[08:58:29][SUCCESS] connection succeeded, continuing
[08:58:29][INFO] running single web application 'http://certifiedhacker.com'
[08:58:29][WARN] URL does not appear to have a query (parameter), this may interfere with the detecti
Menu
whatwaf -u http://cert...



1. Verify that WhatWaf identifies **ModSecurity** and Open Source WAF protecting the target application. Close the terminal window.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 7.6.1.1** On the Parrot Security machine, utilize the Nmap script to detect Web Application Firewalls (WAF) and Intrusion Detection/Prevention Systems (IDS/IPS). Additionally, use the WhatWaf tool to identify the WAF protecting a web application. Enter the option that is used to specify URL in WhatWaf. [!SUCCESS] ✅ **Answer:** **-u**